BCSE 0611: APPLICATION AND DATA SECURITY

Course Objectives: *This course introduces web and database security, Email security, Mobile application security (Android, IOS), cloud security, GRC.*

Prerequisites: Basic Information Security and Cybersecurity Knowledge

Credits: 03 **L-T-P-J:3-0-0-0**

Module No.	Contents	Hours (Approx.)
I	**Secure Development Life Cycle (SDLC):** Importance of SDLC: Software development methods; Web application security principles: Application design & development security, Environment and controls, Essence of secure software development, Secure Coding Practices, Threat Modelling, Security Testing (SAST and DAST). **Input Validation & Data Security:** Input Validation & Sanitization (Whitelist, Blacklist, Pattern Matching), Encoding & Canonicalization, Parameterized Queries, Error Handling & Logging, Content Security Policy, Sensitive Data Protection, Common Attacks (XSS, Buffer Overflow, Path Traversal, Command Injection, Data Tampering), and Countermeasures. **Authentication & Authorization:** User Authentication, Threats (Brute Force, Dictionary, Credential Theft, Phishing, Elevation of Privilege, Cookie Replay, Luring), Session Management (Security Headers, Cookies, CSRF, Session Hijacking/Fixation), Network Eavesdropping, and Countermeasures. **Database Security:** SQL Injection, Database Auditing and Monitoring (Activity Logs, Anomaly Detection), Backup and Recovery Strategies (Regular Backups, Disaster Recovery Plans), Access Control Mechanisms (Granular Access Control, Least Privilege Principle), Patch Management, Data Masking and Tokenization, countermeasures	20
II	**Mobile Security**: Android architecture, Rooting, Mobile App Security Vulnerabilities (OWASP TOP 10), Mobile APK Penetration Testing (MobSF, Burpsuite, Frida), Intercepting TLS Traffic, Android Malware analysis (static analysis (jadx tool) and dynamic analysis (Sandbox)), Reverse-Engineering Obfuscated Applications (jadx, Ghidra), RAT for Mobile, countermeasures **Cloud Security:** Introduction to cloud computing, Types of cloud computing, Cloud Service Models (IaaS, PaaS, SaaS etc..), Cloud Deployment Models (Public, Private, Hybrid), Docker Container Security, Exploiting S3 Bucket, tools: s3scanner, s3Inspector **Introduction to GRC:** Overview of Governance, Risk Management, and Compliance, Importance of GRC in Information Security, Key concepts and terminology, Principles of security audits and assurance, Roles and responsibilities in audits, Introduction to audit frameworks, ISO 27001, NIST SP 800-53, and COBIT, Implementing GRC policies, Case studies on framework adoption, Risk identification and assessment techniques, Qualitative vs. Quantitative risk analysis, Risk mitigation strategies	20

Reference Books:

- The Mobile Application Hacker's Handbook" by Dominic Chell, Tyrone Erasmus, (1st Edition 2015)
- Android Security Internals: An In-Depth Guide to Android's Security Architecture" by Nikolay Elenkov (1st Edition 2014)
- iOS Application Security: The Definitive Guide for Hackers and Developers" by David Thiel (1st Edition 2016)
- Security Information and Event Management (SIEM) Implementation" by David Miller (1st Edition 2010)
- SOAR: A Definitive Guide" by Joseph Muniz (1st Edition 2020)
- Security Operations Center: Building, Operating, and Maintaining Your SOC" by Joseph Muniz, Gary McIntyre, and Nadhem AlFardan (1st Edition 2015)
- AWS Security Best Practices" by Albert Anthony (1st Edition 2018)
- "IT Governance: An International Guide to Data Security and ISO27001/ISO27002" (6th Ed. 2020)

Focus: Core principles and practices in securing digital information systems.
Employability: Entry roles in IT support, cyber hygiene training, and junior analyst positions.

Outcome: Upon completion of this course, the students will be able to:

CO1: Understand Secure Development Life Cycle (SDLC) and Secure Coding Practices
CO2: Implement Input Validation and Secure Data Handling
CO3: Analyze and Design Secure Authentication and Authorization Systems

CO4: Apply Database Security and Data Protection Mechanisms
CO5: Evaluate and Secure Mobile Applications
CO6: Implement Cloud Security Best Practices
CO7: Apply Governance, Risk Management, and Compliance (GRC) frameworks and standards.

Mapping of Course Outcomes (COs) with Program Outcomes (POs) and Program Specific Outcomes (PSOs):

COs	POs/PSOs
CO1	PO1, PO2 / PSO1
CO2	PO1, PO3, PO5/PSO1
CO3	PO1, PO2, PO4/PSO1
CO4	PO1, PO3, PO5/PSO1
CO5	PO1, PO2, PO4/PSO1
CO6	PO1, PO3, PO5/PSO1
CO7	PO1, PO2, PO4/PSO1

BCSE 0641: APPLICATION AND DATA SECURITY LAB

Objective: *To equip students with practical skills in identifying and mitigating security vulnerabilities in web, mobile, cloud, and container environments, while introducing key tools and techniques for secure coding, access control, and threat detection.*

Prerequisites: Basic Information Security and Cybersecurity Knowledge

Credits:01 **L-T-P-J:0-0-2-0**

Module No.	Content	Teaching Hours
I & II	• Input Validation and Sanitization • Cross-Site Scripting (XSS) Prevention • Stack-Based Buffer Overflow • SQL Injection Attack and Defense • Command Injection Vulnerability and Prevention • Countering Brute Force and Dictionary Attacks • Demonstrating a CSRF Attack • Backup and Restore of Databases • Access Control Mechanisms (Granular Access Control and Least Privilege) • Mobile App Security Vulnerabilities (OWASP Mobile Top 10) • Reverse Engineering Obfuscated Mobile Applications • Simulate an Attack on Misconfigured Cloud Storage (S3 Bucket Attack) • Inspect and Analyze Docker Images for Security Vulnerabilities • Setup Splunk and Components Overview • Setup wazuh and Components Overview	24

Reference Books:

- The Web Application Hacker's Handbook (2nd Edi 2011)
- OWASP Mobile Security Testing Guide (MSTG) v1.2 (2020)
- Practical Cloud Security: A Guide for Secure Design and Deployment (1st Edi. 2019)
- Splunk Essentials, **Authors:** Betsy Page Sigman & Erickson Delgado (2nd Edi 2016)

Focus: This Course focuses on employability under CO1, CO2, CO3.

Focus: Core principles and practices in securing digital information systems.
Employability: Entry roles in IT support, cyber hygiene training, and junior analyst positions.

Outcome: After completion of course, the student will be able to:

CO1: Identify and demonstrate common security vulnerabilities in web, mobile, and cloud applications using hands-on tools and techniques.
CO2: Apply appropriate defense mechanisms such as input validation, secure coding, access control, and attack prevention strategies.
CO3: Utilize industry tools like Splunk and Wazuh for monitoring, threat detection, and security incident analysis

Mapping of Course Outcomes (COs) with Program Outcomes (POs) and Program Specific Outcomes (PSOs):

COs	POs/PSOs
CO1	PO1, PO3, PO5/PSO1
CO2	PO1, PO3, PO5/PSO1
CO3	PO1, PO3, PO5/PSO1